GUÍA TÉCNICA COLOMBIANA

GTC-ISO/IEC 27032:2023

Ciberseguridad. Orientaciones para la seguridad en Internet

E: Cybersecurity. Guidelines for Internet security

CORRESPONDENCIA: esta Guía Técnica Colombiana es una adopción idéntica (IDT) por traducción de la norma ISO/IEC 27032:2023, Edición 2.0 y está cubierta por los derechos de autor y otros derechos de propiedad intelectual de IEC, según el acuerdo de licencia con esta entidad

DESCRIPTORES: incidentes de seguridad; gestión de activos; gestión de vulnerabilidad; *malware*

I.C.S.: 35.030

® ICONTEC 2023

Reservados todos los derechos. Ninguna parte de esta publicación puede ser reproducida o utilizada en cualquier forma o por cualquier medio, electrónico o mecánico incluyendo fotocopiado y microfilmación, sin permiso por escrito del editor.

Editada por ICONTEC. Bogotá, D.C. Tel. (57) (601) 5806419

Edición 2.0

Prohibida su reproducción | Editada 2023-12-06

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

PRÓLOGO

El Instituto Colombiano de Normas Técnicas y Certificación (ICONTEC) es el organismo nacional de normalización, según el Decreto 1595 de 2015.

ICONTEC es una entidad de carácter privado, sin ánimo de lucro, cuya Misión es fundamental para brindar soporte y desarrollo al productor y protección al consumidor. Colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el período de Consulta Pública, este último caracterizado por la participación del público en general.

Se llama la atención sobre la posibilidad de que algunos elementos de este documento pueden ser objeto de derechos de patente. ICONTEC no asume la responsabilidad por la identificación de dichas patentes, o por la documentación que se haya aportado que goza de esta protección legal.

La GTC-ISO/IEC 27032:2023 fue estudiada por el CTN 181 – Gestión de la tecnología de la información, y ratificada por el Consejo Directivo de 2023-12-06.

Este documento está sujeto a ser revisado en cualquier momento con el objeto de que responda a las necesidades y exigencias actuales. Se invita a los usuarios de este documento a presentar sus solicitudes de revisión a ICONTEC; sus comentarios serán puestos a consideración del comité técnico responsable del estudio de este tema.

ICONTEC cuenta con un Centro de Información que pone a disposición de los interesados normas internacionales, regionales y nacionales y otros documentos relacionados.

DIRECCIÓN DE NORMALIZACIÓN

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

CONTENIDO

INTRODUCCIÓN I

1. OBJETO Y CAMPO DE APLICACIÓN 1

2. REFERENCIAS NORMATIVAS 1

3. TÉRMINOS Y DEFINICIONES 1

4. TÉRMINOS ABREVIADOS 4

5. RELACIÓN ENTRE SEGURIDAD EN INTERNET, SEGURIDAD EN LA WEB, SEGURIDAD DE REDES Y CIBERSEGURIDAD 5

6. VISIÓN GENERAL DE LA SEGURIDAD EN INTERNET 7

7. PARTES INTERESADAS 9

7.1 Generalidades 9

7.2 Usuarios 9

7.3 Coordinadores y organismos de normalización 11

7.4 Autoridades gubernamentales 11

7.5 Fuerzas de orden público 11

7.6 Proveedores de servicios de Internet 11

8. EVALUACIÓN Y TRATAMIENTO DE LOS RIESGOS PARA LA SEGURIDAD EN INTERNET 12

8.1 Generalidades 12

8.2 Amenazas 12

8.3 Vulnerabilidades 13

8.4 Vectores de ataque 14

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

9. DIRECTRICES DE SEGURIDAD PARA INTERNET 15

9.1 Generalidades 15

9.2 Controles para la seguridad en Internet 16

ANEXO A (INFORMATIVO) REFERENCIAS CRUZADAS ENTRE ESTE DOCUMENTO Y LA GTC-ISO/IEC 27002 31

BIBLIOGRAFÍA 33

DOCUMENTO DE REFERENCIA 35

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

INTRODUCCIÓN

El objetivo de este documento es abordar los problemas de seguridad en Internet y proporcionar orientaciones para enfrentar amenazas comunes de la seguridad en Internet, tales como:

- ataques de ingeniería social;
- ataques de día cero;
- ataqu0065s a la privacidad;
- jaqueo; y
- la proliferación de programas maliciosos (*malware*), programas espía (*spyware*) y otros programas potencialmente no deseados.

Las orientaciones contenidas en este documento proporcionan controles técnicos y no técnicos para enfrentar los riesgos de seguridad en Internet, lo que comprende controles para:

- prepararse para los ataques;
- prevenir los ataques;
- detectar y controlar los ataques; y
- responder a los ataques.

Las orientaciones se enfocan en proporcionar las mejores prácticas del sector y dar una amplia formación a consumidores y empleados, para ayudar a las partes interesadas a desempeñar un rol activo a la hora de enfrentar los desafíos que plantea la seguridad en Internet. El documento también se enfoca en la preservación de la confidencialidad, la integridad y la disponibilidad de la información a través de Internet, y otras propiedades, como la autenticidad, la responsabilidad, el no repudio y la confiabilidad, que también pueden estar implicadas.

Esto comprende las orientaciones sobre seguridad en Internet para:

- Roles.
- Políticas.
- Métodos.
- Procesos.
- Controles técnicos aplicables.

Dado el alcance de este documento, los controles proporcionados son necesariamente de alto nivel. Las normas y directrices técnicas detalladas aplicables a cada área se citan en el documento para su consulta adicional. Véase el Anexo A (Informativo) para la correspondencia entre los controles citados en este documento y los de la GTC-ISO/IEC 27002.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Este documento no aborda específicamente los controles que las organizaciones pueden requerir en sistemas que dan soporte a infraestructuras críticas o a la seguridad nacional. No obstante, la mayoría de los controles mencionados en este documento se pueden aplicar a dichos sistemas.

Este documento utiliza conceptos existentes de la GTC-ISO/IEC 27002, la NTC-ISO/IEC TS 27100 y NTC-ISO/IEC 27701 y de la serie de normas ISO/IEC 27033, para ejemplificar:

- La relación entre la seguridad en Internet, la seguridad en la web, la seguridad de redes y la ciberseguridad.
- Las orientaciones detalladas sobre los controles de seguridad en Internet, citadas en el numeral 9.2, que abordan la preparación para la ciberseguridad en sistemas orientados a Internet.

Como se menciona en la NTC-ISO/IEC TS 27100, Internet es una red global, que las organizaciones utilizan para todas las comunicaciones, tanto digitales como de voz. Dado que algunos usuarios dirigen sus ataques hacia estas redes, es fundamental abordar los riesgos de seguridad que sean pertinentes.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

CIBERSEGURIDAD. ORIENTACIONES PARA LA SEGURIDAD EN INTERNET

1. OBJETO Y CAMPO DE APLICACIÓN

Este documento proporciona:

- Una explicación de la relación entre la seguridad en Internet, la seguridad en la web, la seguridad de redes y la ciberseguridad.
- Una visión general de la seguridad en Internet.
- Una identificación de las partes interesadas, y una descripción de sus roles en la seguridad en Internet.
- Orientaciones de alto nivel para abordar problemas comunes de seguridad en Internet.

Este documento está dirigido a las organizaciones que utilizan Internet.

2. REFERENCIAS NORMATIVAS

Los siguientes documentos normativos se referencian en el texto de tal manera que parte o la totalidad de su contenido constituye requisitos para este documento. Para las referencias fechadas, se aplica únicamente la edición citada. Para referencias no fechadas, se aplica la última edición del documento referenciado (incluida cualquier corrección).

NTC-ISO/IEC 27000, Tecnología de la información. Técnicas de seguridad. Sistemas de gestión de la seguridad de la información. Visión general y vocabulario

3. TÉRMINOS Y DEFINICIONES

Para los propósitos de este documento, se aplican los términos y definiciones establecidos en la NTC-ISO/IEC 27000 y los siguientes.

La ISO y la IEC mantienen bases de datos terminológicas para su uso en la normalización en las siguientes direcciones:

- Plataforma de navegación en línea de la ISO: disponible en https://www.iso.org/obp
- IEC Electropedia: disponible en https://www.electropedia.org/

3.1 vector de ataque (*attack vector*). Ruta o medio por el que un atacante puede conseguir acceso a un computador o servidor de red, con el fin de producir un resultado malicioso.

EJEMPLO 1 Dispositivos de IoT.

EJEMPLO 2 Teléfonos inteligentes.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.2 atacante (*attacker*). Persona que aprovecha deliberadamente las vulnerabilidades de los controles de seguridad, técnicos y no técnicos, con el fin de robar o comprometer los sistemas y redes de información, o de comprometer la disponibilidad de los recursos de los sistemas y redes de información para los usuarios legítimos.

[FUENTE: ISO/IEC 27033-1:2015, 3.3]

3.3 ataque combinado (*blended attack*). Ataque que busca maximizar la gravedad del daño y la velocidad de propagación, combinando múltiples vectores de ataque (véase el numeral 3.1)

3.4 robot (*bot*). Programa informático automatizado que se utiliza para realizar tareas específicas.

Nota 1 de la entrada: esta palabra con frecuencia se utiliza para describir programas, normalmente ejecutados en un servidor, que automatizan tareas como el reenvío o la clasificación del correo electrónico.

Nota 2 de la entrada: un robot también se describe como un programa que opera como agente de un usuario o de otro programa, o que simula una actividad humana. En Internet, los robots más comunes son los programas, también conocidos como rastreadores (*crawlers*) o arañas (*spiders*), que acceden a los sitios web y recopilan su contenido para los índices de motores de búsqueda.

3.5 red de robots (*botnet*). Conjunto de robots maliciosos, controlados a distancia, que se ejecutan de forma autónoma o automática en computadores comprometidos.

EJEMPLO Nodos de denegación de servicio distribuido (DDoS), en los que el controlador de la red de robots puede dirigir el computador del usuario para generar tráfico a un sitio de terceros como parte de un ataque DDoS coordinado.

3.6 ciberseguridad (*cybersecurity*). Protección de las personas, la sociedad, las organizaciones y las naciones frente a los riesgos cibernéticos.

Nota 1 a la entrada: proteger significa mantener el riesgo cibernético en un nivel tolerable.

[FUENTE: ISO/IEC TS 27100:2020, 3.2]

3.7 red oscura (*dark net*). Red de sitios web ocultos en Internet, a los que solamente se puede tener acceso con programas informáticos específicos.

Nota 1 de la entrada: a la red oscura también se conoce como web oscura.

3.8 *software* engañoso (*deceptive software*). *Software* que realiza actividades en el computador de un usuario sin notificarle previamente qué hará exactamente el *software* en el computador, o sin pedirle al usuario su consentimiento para estas acciones.

EJEMPLO 1 Un programa que manipula las configuraciones del usuario.

EJEMPLO 2 Un programa que causa interminables anuncios emergentes que el usuario no puede detener fácilmente.

EJEMPLO 3 *Adware* y programas espía.

3.9 jaqueo (*hacking*). Acceso intencional a un sistema informático sin la autorización del usuario o del propietario.

3.10 hacktivismo (*hacktivism*). Realizar jaqueo (véase el numeral 3.9) con fines políticos o sociales.

3.11 Internet (*Internet*). Sistema mundial de redes interconectadas de dominio público.

[FUENTE: ISO/IEC 27033-1:2015, 3.14; modificada: se eliminó el artículo “el” del término].

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.12 seguridad en Internet (*Internet security*) Preservación de la confidencialidad, integridad y disponibilidad de la información en Internet (véase el numeral 3.11).

Nota 1 de la entrada: además, otras propiedades también pueden estar involucradas, como la autenticidad, la responsabilidad, el no rechazo y la confiabilidad.

Nota 2 de la entrada: consulte las definiciones de confidencialidad, integridad, disponibilidad, autenticidad, responsabilidad, no repudio y confiabilidad en la norma ISO/IEC 27000:2018, numeral 3.

3.13 proveedor de servicios de Internet, PSI (*Internet service provider,* ISP). Organización que presta servicios de Internet a un usuario y permite a sus clientes tener acceso a Internet (véase el numeral 3.11).

Nota 1 de la entrada: también se conoce como proveedor de acceso a Internet (PAI).

3.14 contenido malicioso (*malicious content*). Aplicaciones, documentos, archivos, datos u otros recursos que tengan características o capacidades maliciosas incrustadas, camufladas u ocultas en ellos.

3.15 ..... (*malware*); *software* malicioso (*malicious software*) (Admitido). *Software* diseñado con intención maliciosa, que contiene características o capacidades que potencialmente pueden dañar directa o indirectamente al usuario o al sistema informático del usuario.

EJEMPLO Virus, gusanos y troyanos.

3.16 organización (*organization*). Persona o grupo de personas que tiene sus propias funciones, con responsabilidades, autoridades y relaciones, para lograr sus objetivos.

Nota 1 de la entrada: en el ámbito de este documento, un individuo es diferente a una organización.

Nota 2 de la entrada: en general, un gobierno también es una organización. En el ámbito de este documento, los gobiernos se pueden considerar por separado de otras organizaciones para mayor claridad.

[FUENTE: ISO 9000:2015, 3.2.1; modificada: se sustituyeron la Nota 1 a la entrada y la Nota 2 a la entrada].

3.17 ..... (*phishing*). Proceso fraudulento de intentar adquirir información privada o confidencial, haciéndose pasar por una entidad de confianza en una comunicación electrónica.

Nota 1 de la entrada: el *phishing* puede llevarse a cabo mediante ingeniería social o engaño técnico.

3.18 *software* potencialmente no deseado (*potentially unwanted software*) *Software* engañoso (véase el numeral 3.8), incluido el *software malicioso* (véase el numeral 3.15) y no malicioso que presenta las características del *software* engañoso.

3.19 correo no deseado (*spam*). Correos electrónicos no solicitados que pueden contener contenido malicioso y/o mensajes fraudulentos.

Nota 1 de la entrada: aunque la forma más reconocida de *spam* es el correo electrónico, el término se aplica a abusos similares en otros medios: mensajería instantánea, grupos de noticias de Usenet, buscadores web, blogs, wikis, mensajería de telefonía móvil, foros de Internet y faxes basura.

[FUENTE: ISO/IEC 27033-1:2015, 3.37; modificada: se agregó la Nota 1 a la entrada].

3.20 programa espía (*spyware*). *Software* engañoso (véase el numeral 3.8), que recopila información privada o confidencial de un usuario de computador.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 1 de la entrada: la información puede incluir elementos como los sitios web visitados con más frecuencia o datos más sensibles, como contraseñas.

3.21 amenaza (*threat*). Causa potencial de un incidente no deseado, que puede resultar perjudicial para un sistema, una persona o una organización (véase el numeral 3.16).

3.22 troyano (*trojan*). *Malware* (véase el numeral 3.15) que aparenta realizar una función deseable para el usuario, pero que lo engaña sobre su verdadera intención.

3.23 ..... (*vishing*). Phishing por voz, realizado para obtener información privada o confidencial, haciéndose pasar por una entidad de confianza.

Nota 1 de la entrada: el vishing puede realizarse por correo electrónico de voz, VoIP (voz sobre IP) o teléfono fijo o móvil.

3.24 ataque de abrevadero (*waterhole technique*). Técnica que incita a la gente a acceder a un sitio web que contiene específicamente (mucho) *malware*.

Nota 1 de la entrada: “abrevadero” también se conoce como “pozo de agua”.

3.25 red informática mundial (*World Wide Web*); red (*Web*) (admitido). Universo de información y servicios, accesibles en red.

[FUENTE: ISO 19101-1:2014, 4.1.40]

4. TÉRMINOS ABREVIADOS

En este documento se utilizan las siguientes abreviaturas.

IA	inteligencia artificial
API	interfaz de programación de aplicaciones
APT	amenaza persistente avanzada
BYOD	trae tu propio dispositivo
CERT	equipo de respuesta a emergencias informáticas
DDoS	denegación de servicio distribuida
DLP	prevención de pérdida de datos
DMZ	zona desmilitarizada
DNS	sistema de nombres de dominio
DoS	denegación de servicio
EDR	detección y respuesta de puntos finales
FTP	protocolo de transferencia de archivos
HTTP	protocolo de transferencia de hipertexto

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

HTTPS	protocolo seguro de transferencia de hipertexto
ICANN	Corporación de Internet para la Asignación de Nombres y Números
TIC	tecnología de la información y la comunicación
IDS	sistema de detección de intrusos
IETF	Grupo de Trabajo de Ingeniería de Internet
IMT	equipo de gestión de incidentes
IoT	Internet de las cosas
IP	protocolo de Internet
IPS	sistema de prevención de intrusiones
PSI	proveedor de servicios de Internet
ISV	proveedor independiente de *software*
ERI	equipo de respuesta a incidentes
SGSI	sistema de gestión de la seguridad de la información
OWASP	Proyecto Abierto de Seguridad de Aplicaciones Web
IIP	información de identificación personal
SDLC	ciclo de vida del desarrollo de *software*
SIEM	gestión de eventos e información de seguridad
pyme	pequeña y mediana empresa
URL	localizador uniforme de recursos
USB	bus serie universal
VPN	red privada virtual
W3C	Consorcio World Wide Web
WWW	red informática mundial (WWW)

5. RELACIÓN ENTRE SEGURIDAD EN INTERNET, SEGURIDAD EN LA WEB, SEGURIDAD DE REDES Y CIBERSEGURIDAD

La Figura 1 presenta una visión de alto nivel de la relación entre seguridad en Internet, seguridad de redes, seguridad de redes y ciberseguridad.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

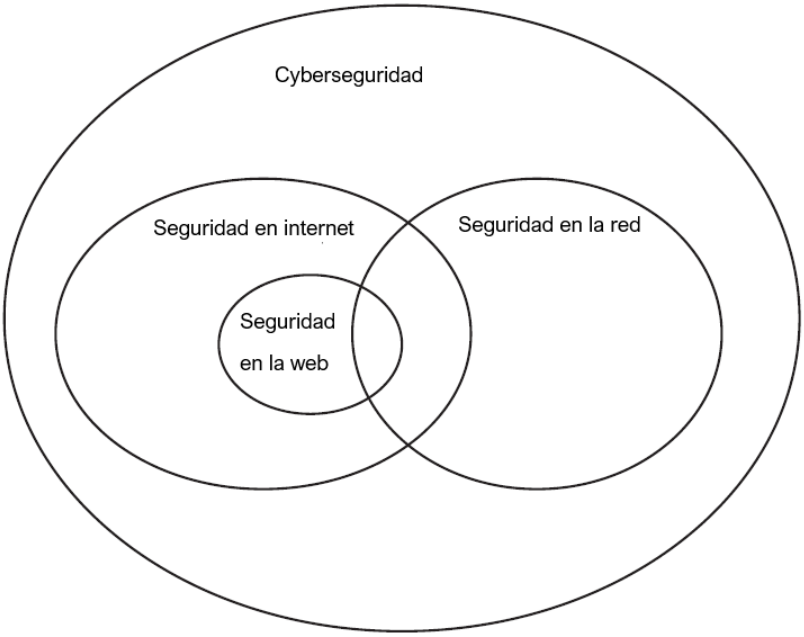


Figura 1.Relación entre seguridad en Internet, seguridad en la web, seguridad de redes y ciberseguridad

Internet es un sistema mundial de redes digitales interconectadas, en el dominio público. El intercambio de información en Internet también utiliza la red de telefonía móvil que, por lo tanto, forma parte de Internet. Esta red mundial conecta miles de millones de servidores, computadores y otros dispositivos de *hardware*. Cada dispositivo está conectado con cualquier otro a través de su conexión a Internet. Internet crea un entorno propicio para el intercambio de información.

La seguridad en Internet se ocupa de proteger los servicios relacionados con Internet y los sistemas y redes de TIC relacionados, como extensión de la seguridad de redes. La finalidad de estos esfuerzos es la reducción de los riesgos de seguridad relacionados con Internet para organizaciones, clientes y otras partes interesadas.

La seguridad en Internet también garantiza la disponibilidad y confiabilidad de los servicios de Internet. En Internet se ofrecen variados servicios, tales como servicios de transferencia de archivos, servicios de correo o cualquier otro servicio que se pueda compartir públicamente con los usuarios finales. En este contexto, la seguridad en Internet se ocupa de la prestación segura de estos servicios a través de la red pública.

La web es una de las formas que existen para compartir información en Internet [otras incluyen el correo electrónico, el protocolo de transferencia de archivos (FTP) y los servicios de mensajería instantánea]. La web está compuesta por miles de millones de documentos digitales conectados que se pueden visualizar mediante un navegador web. Un sitio web es un conjunto de páginas web relacionadas, que se preparan y mantienen como una colección como soporte para un único propósito.

La seguridad en la web se ocupa de la seguridad de la información en el contexto de la red informática mundial (WWW) y de los servicios web a los que se accede a través de la red pública. El servicio web está habilitado mediante el uso del protocolo HTTP, en el cual se puede acceder a cualquier URL pública registrada. Así mismo, la seguridad web se ocupa de la seguridad de esta conexión HTTP empleada para el intercambio de información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Una red puede incluir componentes tales como enrutadores, concentradores, cableado, controladores de telecomunicaciones, centros de distribución de claves y dispositivos de control técnico. La seguridad de redes abarca, en general, todos los tipos de redes que existen en una organización: la red de área local, la red de área amplia, la red de área personal y las redes inalámbricas.

La seguridad de redes se ocupa del diseño, implementación, funcionamiento y mejora de las redes, así como de la identificación y el tratamiento de los riesgos de seguridad relacionados con las redes dentro de las organizaciones, entre organizaciones, y entre organizaciones y usuarios.

La ciberseguridad se ocupa de la gestión de los riesgos de seguridad de la información cuando ésta se encuentra en forma digital en computadores, almacenamiento y redes. Muchos de los controles, métodos y técnicas de seguridad de la información se pueden aplicar a la gestión de los riesgos cibernéticos.

La ciberseguridad también se ocupa de proteger los sistemas conectados a Internet, incluidos el *hardware*, el *software*, los programas y los datos, frente a posibles ataques. Muchos de estos ataques se caracterizan por ser ataques dirigidos y combinados, con un alto grado de sofisticación y persistencia. Las amenazas pueden estar basadas en Internet y/o deberse a la conectividad con otras redes y sistemas dentro de la organización o de la red de clientes y proveedores de servicios, con las que la organización se comunica durante el curso normal de su actividad.

6. VISIÓN GENERAL DE LA SEGURIDAD EN INTERNET

La información de identificación personal (IIP) de los usuarios de Internet es captada por muchos sitios y servicios ofrecidos en Internet. Entre ellos hay proveedores de servicios de aplicaciones que siguen de cerca las actividades de los usuarios y utilizan técnicas de inteligencia artificial (IA) para ofrecerles recomendaciones sobre compras, atención en salud, gestión del tiempo y una variedad de retroalimentaciones con la intención de facilitarles la gestión de su vida y sus tareas. Muchos de estos sitios recopilan estos datos sin el permiso de los usuarios y los facilitan a terceros con fines lucrativos, también sin el conocimiento de los usuarios. Las partes interesadas han estado estableciendo su presencia en Internet a través de sitios web, realizando comercio electrónico a escala mundial, mediante la prestación de servicios digitales en Internet, con el uso de servicios de nube pública para prestar servicios, y con el uso de aplicaciones y servicios empresariales basados en la web.

Muchos usos de Internet implican el intercambio de información y la prestación de servicios que no afectan a las personas ni a la IIP. La IIP varía según la jurisdicción. La seguridad de tal información y tales servicios puede ser crítica para las partes interesadas. Además, la gama de *hardware* conectado a Internet, bien sea como dispositivos individuales o como redes privadas, está en rápido aumento en lo que se denomina Internet de las cosas. La autonomía y la aplicación de inteligencia artificial en el Internet de las cosas crean requisitos de seguridad en Internet que suponen un desafío.

Aunque el Internet puede facilitar significativos resultados empresariales, siempre hay muchos riesgos de seguridad por gestionar. Es importante recordar que Internet no se diseñó originalmente pensando en la seguridad. Las organizaciones dependen en gran medida del uso de Internet para realizar sus negocios. Debido al bajo nivel de confianza asociado a Internet, las operaciones del negocio pueden enfrentarse a importantes consecuencias adversas derivadas de la pérdida de confidencialidad, integridad y disponibilidad de la información y los servicios, si no se controlan de una forma adecuada.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Aunque algunos individuos son cuidadosos en la gestión de su identidad en línea, la mayoría de las personas sube detalles de sus perfiles personales para compartirlos con otros. Los perfiles de muchos sitios, en particular de las redes sociales y las salas de chat, pueden ser descargados y almacenados por terceros. Esto puede conducir a la creación de un archivo digital de datos personales que se puede utilizar indebidamente, revelarse a otras partes o utilizarse para la recopilación secundaria de datos. Aunque la exactitud e integridad de estos datos son cuestionables, crean vínculos con personas y organizaciones, los cuales, con frecuencia, no pueden borrarse por completo. Estos avances en los ámbitos de la comunicación, el ocio, el transporte, las compras, las finanzas, los seguros y la asistencia en salud crean nuevos riesgos para las partes interesadas en Internet. Por lo tanto, hay riesgos que pueden asociarse con la pérdida de privacidad en Internet.

La convergencia de las tecnologías de la información y la comunicación, la facilidad para acceder al Internet, desde en computadores de escritorio y portátiles hasta en dispositivos móviles y de IoT, y el acortamiento del espacio personal entre individuos están captando la atención de agentes maliciosos y organizaciones delictivas.

Estas entidades utilizan mecanismos, como el *phishing*, el correo electrónico masivo no deseado y los programas espía, además de desarrollar técnicas de ataque como los ataques de día cero, el *vishing*, los sitios web maliciosos y otras técnicas de engaño para explotar cualquier punto débil que puedan descubrir en Internet.

En los últimos años, los ataques a la seguridad en Internet han evolucionado desde la piratería por fama personal a la delincuencia organizada o la ciberdelincuencia. Una abundancia de herramientas y procesos antes observados en incidentes aislados de ciberseguridad se utilizan ahora juntos en ataques combinados múltiples, con frecuencia con objetivos maliciosos de gran alcance.

Muchas de estas herramientas también están disponibles en repositorios públicos de *software* y otros recursos de acceso público. Los objetivos de un ataque van desde los ataques personales, el robo de identidad, los fraudes o robos financieros, hasta el hacktivismo y la manipulación de la información en Internet. Gran parte de los datos personales y de clientes robados también se ponen a disposición en la red oscura, la cual puede ser de acceso público. Las organizaciones, y especialmente las pymes, deberían comprender las consecuencias reales de “manipular” información en Internet. Estos riesgos de seguridad son los riesgos cibernéticos para los usuarios que acceden a Internet.

Como Internet es una red pública mundial, las transacciones se pueden originar en cualquier parte del mundo, al igual que los ataques. Las múltiples modalidades de transacciones comerciales que se llevan a cabo en Internet se están convirtiendo en el objetivo de los sindicatos de la ciberdelincuencia. Los riesgos que se plantean son intrínsecamente complejos, y van desde de empresa a empresa, de empresa a consumidor, hasta de consumidor a consumidor.

Otra complicación se deriva del hecho de que todas las partes interesadas, incluso cuando no son malintencionadas, tienen una visión diferente de sus necesidades, requisitos y amenazas, por lo que tienen una lista diferente de riesgos y controles para contrarrestarlos. Esto significa que no existe una solución única.

Los criterios, como qué constituye una transacción o un acuerdo, dependen de los entornos jurídicos y normativos específicos de las distintas jurisdicciones. Estos criterios también dependen de la interpretación de la ley y de cómo cada parte de la relación gestiona su responsabilidad. Con frecuencia, la cuestión del uso de los datos recopilados durante la transacción o la relación no se aborda de una forma adecuada. Esto podría provocar, eventualmente, problemas de seguridad, tales como la fuga de información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los desafíos jurídicos y técnicos que plantean estas cuestiones de Internet son de gran alcance y de naturaleza mundial. Estos desafíos solo se pueden abordar mediante la colaboración entre la comunidad técnica de la seguridad de la información, la comunidad jurídica y las distintas regiones para adoptar una estrategia consistente. Esta estrategia debería tomar en consideración, dentro de un marco de cooperación internacional, el rol de cada parte interesada y las iniciativas existentes.

La información viaja por Internet de forma instantánea, lo que significa que los ataques también se pueden producir instantáneamente. Como estas velocidades no son fácilmente comprensibles para la mente humana, el ataque siempre se descubre mucho tiempo después de haberse producido y los daños ya son potencialmente enormes. En la mayoría de casos, la identidad de los atacantes está oculta. Por ello, se propone con frecuencia el uso de la inteligencia artificial (IA) para contrarrestar los ataques.

7. PARTES INTERESADAS

7.1 Generalidades

Entre las partes interesadas en la seguridad en Internet se encuentran quienes:

- Utilizan servicios a través de Internet.
- Utilizan Internet para prestar servicios.
- Proporcionan la infraestructura y las capacidades de comunicación de Internet.
- Coordinan globalmente el funcionamiento de Internet.
- Establecen y aplican leyes y reglamentos.

Las partes interesadas en la seguridad en Internet se pueden clasificar en usuarios (véase el numeral 7.2), coordinadores y organismos de normalización (véase el numeral 7.3), autoridades gubernamentales (véase el numeral 7.4), fuerzas de orden público (véase el numeral 7.5) y proveedores de servicios de Internet (véase el numeral 7.6).

7.2 Usuarios

El término “usuarios” se refiere a los individuos, los usuarios finales, y las organizaciones privadas y públicas que utilizan Internet. Entre las organizaciones privadas se incluyen las pequeñas y medianas empresas (pymes), así como las grandes empresas. Los gobiernos y otros organismos públicos se denominan colectivamente organizaciones públicas. Un individuo o una organización se convierte en usuario cuando tiene acceso a Internet o a cualquier servicio disponible a través de éste. Los usuarios pueden hacer uso de los servicios de Internet, ver o recopilar información. También pueden proporcionar cierta información específica que esté dentro del espacio de una aplicación, o que esté disponible para miembros o grupos limitados dentro del espacio de la aplicación, así como para el público en general.

Los roles de usuario pueden incluir, entre otras, las siguientes:

- Usuario general de aplicaciones de Internet, o usuario general, por ejemplo, jugador de juegos en línea, usuario de mensajería instantánea o internauta.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Comprador/vendedor, que participa en la colocación de bienes y servicios en sitios de subastas y mercados en línea para compradores interesados, y viceversa.

- *Blogger* y otros contribuidores de contenidos (por ejemplo, un autor de un artículo en una wiki), quienes publican información en texto y multimedia (por ejemplo, videoclips) para consumo del público en general o de una audiencia limitada.

- Miembro de una organización (por ejemplo, un empleado de una empresa, u otro tipo de asociado con una empresa).

- Otros roles, por las que a un usuario se le puede asignar un rol involuntariamente o sin su consentimiento.

EJEMPLO 1 Cuando un usuario visita un sitio que requiere autorización y, de forma intencionada o no, consigue acceso a él, se le puede etiquetar como un intruso.

EJEMPLO 2 Un individuo, quien actúe como comprador o vendedor, puede participar sin saberlo en transacciones delictivas de venta de bienes robados o en actividades de lavado de activos.

Las organizaciones suelen utilizar Internet para dar a conocer información empresarial e información relacionada, así como para comercializar productos y servicios relacionados. Las organizaciones también utilizan Internet como parte de su red para la entrega y recepción de mensajes electrónicos (por ejemplo, correos electrónicos) y otros documentos (por ejemplo, transferencia de archivos).

De acuerdo con los mismos principios de ser un buen ciudadano corporativo, estas organizaciones deberían extender sus responsabilidades corporativas a Internet, al asegurarse proactivamente de que sus prácticas y acciones en el uso de Internet no introducen riesgos adicionales de seguridad en la comunidad de usuarios de Internet.

Algunas medidas proactivas son:

- La gestión de la seguridad de la información, mediante la implementación y el funcionamiento de un sistema de gestión de la seguridad de la información (SGSI) eficaz (véase la NTC-ISO/IEC 27001 para los requisitos de los sistemas de gestión de la seguridad de la información).

- La aplicación de controles basados en la GTC-ISO/IEC 27002 y otras normas pertinentes, sin el funcionamiento de un SGSI.

- La supervisión de la seguridad y respuesta a incidentes.

- La incorporación de la seguridad como parte del ciclo de vida de desarrollo de *software* (SDLC), en el que el nivel de seguridad incorporado a los sistemas se debería determinar en función de la criticidad de los datos de la organización.

- La formación periódica en materia de seguridad de los usuarios de la organización, mediante actualizaciones continuas de la tecnología y los procesos, además del seguimiento de los últimos avances tecnológicos.

- La comprensión y uso de canales adecuados para comunicarse con vendedores y proveedores de servicios, en relación con las cuestiones de seguridad descubiertas durante el uso.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

7.3 Coordinadores y organismos de normalización

Los coordinadores y las organizaciones de normalización (ICANN, IETF, W3C, entre otros) desarrollan normas técnicas sobre el uso de Internet y los servicios que prestan los proveedores de servicios. Así mismo, asesoran a las organizaciones sobre sus roles y responsabilidades en Internet.

7.4 Autoridades gubernamentales

Los gobiernos poseen información sobre seguridad nacional, cuestiones estratégicas, militares y de inteligencia, entre otros muchos elementos relacionados con el gobierno y el Estado, pero también un vasto conjunto de información sobre individuos, organizaciones y la sociedad como un todo.

Los gobiernos deberían proteger la infraestructura y la información de su propio país del acceso y la explotación no autorizados. Existe una tendencia creciente y en expansión de ofrecer servicios de gobierno electrónico mediante Internet. Este es un nuevo canal, entre otros, para lanzar ataques y tener acceso a la información antes mencionada que, de tener éxito, pueden resultar en un grave impacto para una región, su gobierno y la sociedad.

Las autoridades gubernamentales desempeñan un rol de coordinación entre las fuerzas de orden público y son el coordinador principal de la difusión de información y de orquestar los recursos necesarios, tanto a nivel nacional como corporativo, en momentos de crisis derivados de un ciberataque masivo. Esto incluye también a autoridades como un CERT y organizaciones similares a las que se confían tales responsabilidades, según la región específica en contexto.

Los gobiernos ordenan los programas de educación en ciberseguridad de universidades y escuelas secundarias, y garantizan que se organice una adecuada asociación público-privada, con la estructura legal necesaria, que organice a las fuerzas de orden público y defina sus misiones.

7.5 Fuerzas de orden público

Las fuerzas del orden público hacen cumplir la normativa y responsabilizan a todas las partes interesadas en cuanto al cumplimiento de la normativa relevante dentro de su jurisdicción nacional.

7.6 Proveedores de servicios de Internet

Las organizaciones proveedoras de servicios pueden incluir dos categorías:

- Proveedores de acceso a Internet para empleados y socios.
- Proveedores de servicios a consumidores de Internet.

Estos servicios se prestan a una comunidad cerrada (por ejemplo, usuarios registrados), o bien al público en general, mediante el suministro de aplicaciones, incluidos los proveedores de servicios en la nube a través de Internet. Un consumidor también puede ser un proveedor de servicios si, a su vez, presta un servicio a través de Internet o permite a otro consumidor el acceso a Internet.

Los proveedores de servicios también pueden entenderse como transportistas o mayoristas, frente a los distribuidores y minoristas de servicios de acceso. Esta diferenciación es importante desde el punto de vista de la seguridad y, sobre todo, de la aplicación de la ley. En caso de que un distribuidor o minorista sea incapaz de proporcionar una seguridad adecuada o un acceso legal, los servicios de

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

asistencia suelen dirigirse al transportista o mayorista. Los proveedores de servicios de Internet (PSI) pueden prestar apoyo mediante la supervisión del "tráfico" y la oferta de rutas o *hosts* alternativos para el control del tráfico. También podrían buscar transferencias "peligrosas" a través de Internet. Con las autorizaciones legales y de los usuarios necesarias, pueden filtrar elementos peligrosos, como ocurre con las soluciones que proporcionan "entornos de prueba" (*sand boxes*) para verificar los archivos transferidos en busca de *malware*. Los PSI pueden avisar a sus clientes cuando descubran patrones de amenazas.

8. EVALUACIÓN Y TRATAMIENTO DE LOS RIESGOS PARA LA SEGURIDAD EN INTERNET

8.1 Generalidades

La NTC-ISO 31000 proporciona principios y orientaciones genéricas sobre la gestión de riesgos, mientras que la NTC-ISO/IEC 27005 proporciona directrices y procesos para la gestión de riesgos de seguridad de la información en una organización, que apoyan los requisitos de un SGSI según lo dispuesto en la NTC-ISO/IEC 27001. Las orientaciones y procesos proporcionados por estos documentos se recomiendan para abordar la gestión de riesgos en el contexto de Internet. Es responsabilidad de las partes interesadas definir su enfoque para la gestión de riesgos. Bajo el marco descrito en la NTC-ISO/IEC 27005, se pueden utilizar varias metodologías existentes para realizar una evaluación de riesgos y gestionar los riesgos asociados con el uso de Internet por parte de la organización, tomando en consideración las amenazas y vulnerabilidades pertinentes y los problemas de seguridad en Internet.

En las organizaciones que disponen de recursos limitados, los controles requerirán tomar en consideración la racionalidad entre las necesidades organizacionales de seguridad y los recursos, para evitar errores en la selección de los controles. Una selección inadecuada de los controles puede originar riesgos adicionales o a controles ineficaces.

8.2 Amenazas

Un agente de amenaza es un individuo o grupo de individuos que desempeñan algún rol en la ejecución o apoyo de un ataque. Comprender a fondo sus motivos (religiosos, políticos, económicos, entre otros), capacidades (conocimientos, financiación, tamaño, entre otros) e intenciones (diversión, crimen, espionaje, entre otros) es fundamental en la evaluación de vulnerabilidades y riesgos, así como en el desarrollo y aplicación de controles.

El *malware* puede poner en peligro los controles de seguridad (por ejemplo, la captura y divulgación de contraseñas), la divulgación involuntaria de información, los cambios involuntarios en la información, la destrucción de información o el uso no autorizado de los recursos del sistema. El *malware* se distribuye normalmente a través de virus, gusanos y troyanos, con consecuencias de gran alcance.

Un virus es un programa ejecutable y replicable que inserta su propio código en programas legítimos, con el objetivo de dañar el computador anfitrión (es decir, borrar archivos y programas, corromper el almacenamiento y los sistemas operativos). En su estado más simple, un gusano es un programa informático, destinado a autorreplicarse y propagarse a otros computadores a través de mensajes salientes a todas las direcciones de la lista de contactos de un usuario, para agotar los recursos de un sistema. Además, al igual que un virus, un gusano puede propagar código que puede dañar a su anfitrión. Dicho código se denomina carga útil (por ejemplo, la capacidad de cifrar archivos en el

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

caso del *ransomware*, y la instalación de puertas traseras del sistema que permitan el acceso remoto). Un troyano es un programa malicioso, disfrazado como *software* legítimo o incrustado en él, que tiene objetivos similares a los de los virus y gusanos, pero que, a diferencia de éstos, no se replica ni propaga por sí mismo.

Las amenazas a la seguridad dirigidas a la información de identificación personal (IIP) de los usuarios de Internet giran principalmente en torno a los problemas de identidad que plantean la filtración o el robo de información personal. Si la identidad en línea de una persona es robada o suplantada, ésta puede verse privada de acceso a servicios y aplicaciones clave. En escenarios más graves, las consecuencias pueden ir desde incidentes financieros hasta incidentes a nivel nacional. El acceso no autorizado a la información financiera de una persona también abre la posibilidad al robo de su dinero y al fraude.

EJEMPLO 1 La información crediticia puede venderse en el mercado negro o la red oscura, lo cual puede facilitar el robo de identidad en línea.

EJEMPLO 2 Otros ejemplos de amenazas que, a su vez, equivalen a amenazas para la vida incluyen el cibermatoneo, el acoso en línea y los delitos de explotación, incluidos la explotación infantil y la trata de personas.

Otra amenaza es la posibilidad de que el punto final, incluidos los dispositivos personales y los BYOD (traiga su propio dispositivo), se convierta en un zombi o un robot. Los dispositivos informáticos pueden verse comprometidos y pasar a formar parte de una red de robots mayor. La presencia en línea y el negocio en línea de una organización son, con frecuencia, el objetivo de criminales cuya intención es algo más que una simple travesura.

A mayor escala, la infraestructura que sustenta Internet también puede ser objeto ataques. Aunque esto no afecta al funcionamiento de Internet de forma permanente, sí afecta a la fiabilidad y disponibilidad de la infraestructura, lo que contribuye a la seguridad en Internet.

A escala nacional o internacional, el Internet es un ámbito en el que prosperan los comportamientos ilegales en una jurisdicción determinada. Debido a la naturaleza del Internet y específicamente a los desafíos que plantea la definición de límites y fronteras, resulta difícil regular y controlar la forma en que puede utilizarse.

Los delincuentes pueden comprar legítimamente las aplicaciones, los servicios y los recursos que facilitan su causa, o también pueden recurrir a medios ilegales de asegurar estos recursos para evitar su detección y rastreo. Esto puede incluir la adquisición de recursos informáticos masivos a través de redes de robots.

Otra amenaza se refiere a la modificación deliberada de información públicamente disponible o sujeta a derechos de propiedad o a la creación de información o noticias falsas que, si se confía en ellas, pueden causar graves daños.

8.3 Vulnerabilidades

Una vulnerabilidad es un punto débil de un activo o control que puede ser explotado por una amenaza. Los fabricantes, desarrolladores de *software* y otros creadores de tecnología producen actualizaciones y parches de seguridad para corregir estos puntos débiles una vez son detectados y solucionados. A medida que los sistemas reciben los parches, se agregan actualizaciones o nuevos elementos. A medida que los sistemas quedan obsoletos, dejan de recibir soporte del fabricante o no se actualizan a la última versión, se pueden introducir nuevas vulnerabilidades. Las partes interesadas deberían tener

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

un profundo conocimiento y comprensión del activo o control en cuestión, así como de las amenazas, los agentes de amenaza y los riesgos implicados, con el fin de realizar una evaluación exhaustiva. Las partes interesadas deberían ser conscientes de las vulnerabilidades de día cero, para las cuales no hay parches disponibles.

Las aplicaciones web a las que se accede a través de Internet son susceptibles de sufrir una serie de vulnerabilidades introducidas por un diseño deficiente, un código mal escrito, y una mala construcción de bibliotecas y ejecutables de producción. Ejemplos de estas vulnerabilidades son la evasión de autenticación, los ataques de inyección en bases de datos y los ataques de scripting entre sitios. En estos ataques, se pueden manipular las peticiones para abusar de la funcionalidad del servidor web.

8.4 Vectores de ataque

Un vector de ataque es un camino o medio por el cual un atacante puede obtener acceso a un computador o servidor de red, con el fin de producir un resultado malicioso.

Los escáneres de puertos son una de las herramientas más antiguas, y todavía muy eficaces, utilizadas por los atacantes. Escanean todos los puertos disponibles en el sistema orientado a Internet para confirmar qué puertos están abiertos. Normalmente, éste es uno de los primeros pasos que ejecuta un posible atacante en el sistema de acceso a Internet objetivo. Aunque el ataque inicial siempre se dirige a un sistema orientado al público (por ejemplo, un enrutador, un servidor, un cortafuegos, un sitio web, entre otros), los atacantes también pueden tratar de explotar activos que residan dentro de la red privada y que están conectados a estos sistemas orientados al público.

Vigilar los canales de comunicación es un vector de ataque simple y fácil. También es uno de los más antiguos. Copiar y analizar el tráfico puede ser extremadamente valioso para detectar puntos de entrada e iniciar otros vectores de amenaza. Un atacante también puede utilizar el secuestro de comunicaciones (por *tailgating* o *piggybacking*) y camuflarse tras la identidad o las credenciales del usuario legítimo, y a sus expensas, sin que éste lo sepa.

Muchos de los ataques en Internet se llevan a cabo mediante *software* malicioso, como programas espía, gusanos y virus. Con frecuencia, la información se obtiene mediante técnicas de *phishing*. Un ataque se puede producir como un vector de ataque singular, o llevarse a cabo como un ataque combinado o un ataque dirigido. Estos ataques pueden propagarse, por ejemplo, a través de sitios web sospechosos, descargas no verificadas, correo electrónico no deseado, explotación remota, explotación de día cero y medios extraíbles infectados.

Otros mecanismos cada vez más utilizados y sofisticados para realizar ataques son los basados en las redes sociales y el uso de archivos corruptos en sitios web legítimos. Los sitios web legítimos también pueden sufrir jaqueos, y algunos de sus archivos se pueden corromper y utilizarse como medio para perpetrar ataques. Las personas tienden a confiar implícitamente en los sitios web que visitan habitualmente. Los atacantes pueden aplicar ataques de abrevadero para comprometer a un grupo específico de usuarios finales al infectar los sitios web visitados con frecuencia. Además de los ataques lanzados por atacantes humanos, los computadores infectados con *malware* también lanzan variados ataques a los computadores conectados circundantes.

Con la proliferación de las aplicaciones *peer-to-peer*, utilizadas habitualmente para compartir archivos como música digital, videos, fotos, entre otros, los atacantes son cada vez más sofisticados a la hora de camuflarse y disfrazar su código malicioso, por medio de archivos intercambiados como troyanos para efectuar sus ataques. Una vez que un atacante, a través del robo de identidad, pueda disfrazarse

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

como el contacto legítimo, el atacante puede atacar a otros y se abre una nueva vía para lanzar los variados tipos de ataques.

Otra técnica es la suplantación de IP, en la que el atacante manipula la dirección IP asociada a sus mensajes, en un intento de disfrazarla como una fuente conocida y de confianza, para obtener así el acceso no autorizado a los sistemas.

El atacante no utiliza siempre el mismo vector de ataque. Utiliza múltiples vectores y los cambia con frecuencia. Algunos ataques se ocultan hasta tal punto que no se detectan hasta que ya es demasiado tarde para el usuario. Los defensores deberían tener esto en cuenta y buscar defensa contra múltiples vectores y no solo contra los que ya se han utilizado contra ellos.

Los dispositivos de IoT, los teléfonos inteligentes, entre otros, pueden conectarse a Internet. Estos dispositivos pueden actuar como un vector de ataque adicional, al igual que cualquier otro dispositivo conectado a Internet, si no se controlan de una forma adecuada cuando se conectan a la red de la organización.

Una amenaza persistente avanzada (APT) es un método de ataque con el objetivo de robar información durante un largo periodo de tiempo, mediante el cual los atacantes obtienen acceso continuo a la red de una organización, se establecen sin ser detectados, se mueven lateralmente, buscan, aprenden y permanecen en la red.

Otro método de ataque antiguo es la fuerza bruta. Este método utiliza el método de ensayo y error para descubrir las credenciales de inicio de sesión, las claves de cifrado, la búsqueda de páginas web ocultas, entre otras. Los atacantes trabajan a través de todas las combinaciones posibles, con la esperanza de adivinar correctamente y obtener acceso a la red y a la información de una organización.

9. DIRECTRICES DE SEGURIDAD PARA INTERNET

9.1 Generalidades

Las partes interesadas pueden evaluar los riesgos tomando en consideración las amenazas que se aplican a sus activos. Este análisis puede ayudar en la selección de controles para contrarrestar los riesgos y reducirlos a un nivel aceptable. Los controles se implementan para reducir la probabilidad o las consecuencias de tales riesgos, y para cumplir los requisitos de seguridad de las partes interesadas (ya sea directa o indirectamente, proporcionando instrucciones a otras partes).

Las vulnerabilidades pueden persistir tras la aplicación de los controles. Dichas vulnerabilidades pueden ser explotadas por agentes de amenaza. Las partes interesadas intentan minimizar el riesgo, dadas otras limitaciones. Las partes interesadas deberían estar seguras de que los controles son adecuados para contrarrestar las amenazas a los activos antes de permitir la exposición de los activos a las amenazas especificadas. Si las partes interesadas no poseen la capacidad de evaluar todos los aspectos de los controles, pueden solicitar la evaluación de los controles a través de organizaciones externas.

Una forma eficaz de enfrentar los riesgos de seguridad en Internet implica una combinación de múltiples estrategias, teniendo en cuenta a las distintas partes interesadas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Estas estrategias comprenden:

- Enfoques específicos del sector, con la colaboración de todas las partes interesadas para identificar y abordar los problemas y riesgos de Internet.
- Una amplia educación de consumidores y empleados, que proporcione un recurso confiable sobre cómo identificar y abordar riesgos específicos de Internet dentro de la organización, así como en la comunidad de usuarios de Internet.
- Soluciones tecnológicas innovadoras para ayudar a proteger a los consumidores de los ataques conocidos basados en Internet, para mantenerse al día y estar preparados contra las nuevas explotaciones.
- Legislación y normativa actualizadas, para que la justicia prevalezca en todas las jurisdicciones.

9.2 Controles para la seguridad en Internet

9.2.1 Generalidades

La mayoría de las organizaciones utilizan Internet para múltiples fines, desde la navegación web, el uso de blogs, el uso de redes sociales y el acceso a servicios públicos en la nube, hasta el intercambio de información y el comercio electrónico. Esto implica compartir información comercial clasificada, incluida la información personal, al realizar transacciones en línea. Internet, al ser una red pública, es propensa a ciertas amenazas únicas. Si no se abordan, estas amenazas resultan en ataques que pueden ser difíciles de manejar.

Las organizaciones deberían desarrollar políticas, procedimientos y capacidad de respuesta para:

a) Definir las normas de uso aceptable de Internet por parte del personal.

b) Definir qué servicios pueden exponerse a través de Internet.

c) Identificar las amenazas, vulnerabilidades y vectores de ataque, y sus riesgos asociados.

d) Definir los roles y responsabilidades de los distintos usuarios de Internet.

e) Generar concienciación en los usuarios sobre las prácticas seguras de utilización de Internet.

f) Especificar los departamentos responsables de gestionar los problemas de seguridad en Internet.

g) Establecer un mecanismo de respuesta a los incidentes de ciberseguridad.

h) Realizar simulacros de seguridad para poner a prueba el mecanismo de respuesta frente a los ataques procedentes de Internet.

De acuerdo con la evaluación de riesgos, se pueden descubrir los variados riesgos pertinentes para la seguridad en Internet que se pueden abordar mediante variados controles, tal como se explica a continuación.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

9.2.2 Políticas de seguridad en Internet

Una organización debería preparar y publicar una política relativa al uso de Internet por parte del personal y otras partes pertinentes, de conformidad con los objetivos de seguridad. Esta determina qué servicios de Internet se utilizan, quién está autorizado a utilizarlos y cuáles son los objetivos de seguridad. Esta política dirige todas las demás directrices para la conexión y el uso seguros de Internet.

Las políticas de seguridad en Internet deberían definirse, ser aprobadas por la dirección, publicarse, comunicarse y ser reconocidas por el personal pertinente, los contratistas y las partes externas. Las políticas de seguridad en Internet deberían estipular el personal autorizado a acceder a Internet, los contenidos que pueden ver, las conductas prohibidas en Internet, entre otros. Se deberían asignar las responsabilidades para todas las actividades relacionadas con Internet y para el diseño, aprobación, implementación, operación y monitoreo de todos los controles específicos aplicables a la seguridad en Internet.

La GTC-ISO/IEC 27002 ofrece orientación adicional sobre las políticas de seguridad en Internet.

9.2.3 Control de acceso

El control de acceso abarca los derechos de acceso, no solo de los usuarios, sino también de otras entidades como dispositivos, aplicaciones o procesos automatizados. Por lo tanto, cada conexión debería ser autenticada, y cada actividad, debidamente autorizada, en función de los roles y permisos establecidos, según las reglas de negocio y de seguridad y a cada entidad se le deberían asignar los permisos de menor privilegio. Esto mejora la trazabilidad del acceso a la información y a los activos, y reduce el anonimato, para aumentar la seguridad.

Deberían establecerse y aplicarse reglas para controlar el acceso físico y lógico a la información y los activos, a otros activos asociados a Internet, y a las instalaciones de procesamiento de la información, en función del valor empresarial y el valor de la información. Las reglas relativas al acceso a la información y los activos esenciales, a otros activos asociados con la información y a las instalaciones de procesamiento de la información deberían ser acordes con una política de control de acceso y una política de clasificación de la información establecidas.

Las cuentas solo deberían estar restringidas a los usuarios autorizados por su puesto de trabajo o función. Cada usuario debería tener cuentas separadas y no deberían compartirse, ni debería utilizarse la misma contraseña para más de una cuenta.

Los derechos de acceso a la información, los sistemas, las aplicaciones y los servicios deberían proporcionarse, revisarse, ajustarse, modificarse y eliminarse de acuerdo con la política y el procedimiento de la organización en materia de control de acceso. La asignación y el uso de derechos de acceso privilegiado deberían estar restringidos y controlados. Deberían implementarse tecnologías y procedimientos de autenticación segura, basados en las restricciones de acceso a la información y las normas de control de acceso correspondientes. Deberían implementarse sistemas de gestión de contraseñas para gestionar y apoyar el proceso de creación de contraseñas y la calidad de estas.

Los sistemas de información conectados directamente a Internet (por ejemplo, infraestructura de cortafuegos, dispositivos perimetrales de red, entre otros) pueden tener uno o más programas de utilidad con privilegios que sean capaces de anular los controles del sistema y de las aplicaciones. Si un atacante consigue tener acceso a cualquiera de los sistemas, estos programas de utilidad con privilegios, si no se controlan de una forma adecuada, pueden resultar en un acceso privilegiado para el atacante.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Estos programas deberían ser controlados de una forma adecuada por la organización para que los intrusos no tengan acceso a dichos programas de utilidad con privilegios y anulen los controles del sistema y de las aplicaciones. La gestión eficaz del acceso debería incluir:

- La revisión periódica de todos los derechos de acceso.
- La revisión periódica de los registros administrativos.

La GTC-ISO/IEC 27002 y la norma ISO/IEC 29146 ofrecen orientación adicional sobre la gestión de accesos.

9.2.4 Educación, concienciación y formación

El personal de la organización (incluida la alta dirección, los administradores de sistemas, el personal informático y los usuarios con privilegios, entre otros) debería recibir información actualizada periódicamente sobre las principales amenazas (por ejemplo, *phishing* y *vishing*) y las medidas a tomar para prevenirlas y responder en caso de una acción indebida.

Cada día aparecen en Internet numerosas amenazas nuevas, que evolucionan continuamente y se vuelven más sigilosas y sofisticadas. Al aplicar un control para contrarrestar un ataque, es posible que los usuarios no sean conscientes de que son víctimas de un ataque nuevo o más sofisticado.

Las organizaciones deberían proporcionar periódicamente material para la concienciación y la formación, dirigido al personal, utilizando variados formatos, como comunicaciones por correo electrónico, formación en línea y mensajería a través de *intranets*, para informar al personal de las amenazas en línea, así como de sus obligaciones de uso aceptable y de notificación de incidentes. Esto proporciona un nivel de comprensión y capta su atención para protegerse a sí mismos y a la organización.

La GTC-ISO/IEC 27002 ofrece orientación adicional sobre educación, concienciación y formación.

9.2.5 Gestión de incidentes de seguridad

Los incidentes de seguridad en Internet pueden ir desde una amplia variedad de ciberataques a los recursos organizativos orientados a Internet, así como a los servidores, bases de datos y aplicaciones que están detrás de los recursos orientados a Internet. Los incidentes de seguridad pueden desencadenarse desde cualquier punto de Internet. A veces, el host que lleva a cabo el ataque puede ser un host comprometido. Algunos incidentes pueden tener una naturaleza sofisticada e implicar habilidades especiales para responder de una forma adecuada. Los incidentes con frecuencia cruzan fronteras nacionales, geográficas y organizativas, y la velocidad del flujo de información y los cambios en el incidente en desarrollo con frecuencia dan un tiempo limitado para que actúen las personas y organizaciones encargadas de responder a la situación.

Debería establecerse un equipo de gestión de incidentes (IMT) con un equipo de respuesta a incidentes (ERI) de apoyo, para proporcionarle a la organización la capacidad de evaluar, responder y aprender de tales incidentes. Los procedimientos de respuesta a incidentes deberían considerar la detección y notificación por medios humanos o automáticos la ocurrencia de eventos de seguridad, como incidentes potenciales y reales. Las herramientas de supervisión implementadas por la organización pueden detectar y enviar eventos de seguridad para la respuesta a incidentes. La inteligencia sobre amenazas es información sobre amenazas y actores de dichas amenazas que ayuda a mitigar eventos dañinos en el ciberespacio. El personal de seguridad de la información debería escanear continuamente

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

fuentes de inteligencia sobre amenazas, como la inteligencia de los medios sociales, la inteligencia humana, la inteligencia técnica o la inteligencia de la web profunda y oscura, recopilar la información y luego analizarla.

Se debería establecer una solución técnica para apoyar el intercambio de información y la coordinación, para ayudar a preparar y responder a los eventos de seguridad y los incidentes cibernéticos. Este es un paso importante que las organizaciones deberían dar como parte de sus controles de seguridad. Dicha solución debería implicar un intercambio de información y una coordinación que deberían ser seguros, eficaces, fiables y eficientes.

Los incidentes relacionados con la seguridad en Internet deberían ser respondidos por un contacto designado y otras personas pertinentes de la organización o partes interesadas. Al aplicar los procedimientos de gestión de incidentes, deberían tomarse en consideración todos los requisitos externos sobre notificación de incidentes a las partes interesadas pertinentes dentro de los plazos definidos (por ejemplo, requisitos de notificación de incidentes a los organismos reguladores dentro de los plazos definidos). La organización debería establecer y mantener contacto con las autoridades legales, reguladoras y supervisoras pertinentes. Las organizaciones también deberían mantener contacto con grupos de interés especial y otros foros especializados en seguridad y asociaciones profesionales.

Existe la necesidad de un intercambio de información, una coordinación y un manejo de incidentes eficaz y eficiente entre las partes interesadas en la seguridad de Internet. Esta colaboración debería realizarse de una manera segura y confiable, que proteja también la privacidad de las personas afectadas. Muchas de las partes interesadas pueden residir en lugares geográficos y zonas horarias diferentes, y es probable que se rijan por requisitos normativos distintos.

El intercambio de información y la colaboración comprenden:

- Elementos clave de las consideraciones para establecer la confianza.
- Procesos necesarios para la colaboración y el intercambio de información.
- Requisitos técnicos para la integración e interoperabilidad de los sistemas entre las distintas partes interesadas.

La organización que utilice Internet debería definir y aplicar procedimientos para la identificación, recopilación, adquisición y conservación de información que pueda servir como evidencia en caso de un incidente de seguridad. Se espera que las evidencias se recopilen de manera que sean admisibles en los tribunales nacionales o las autoridades internacionales competentes, en caso de que se demuestre que el incidente se originó en otro país, según los registros de supervisión y otras evidencias digitales.

Las evidencias digitales pueden trascender las fronteras organizacionales o jurisdiccionales en caso de un incidente de seguridad. En tales casos, se debería asegurar que la organización tiene derecho a recopilar la información necesaria como evidencia digital para futuras actuaciones. La correcta configuración de los relojes informáticos es importante para asegurar la exactitud de los registros de auditoría, los cuales pueden esperarse en las investigaciones en caso de cualquier ataque desde Internet, o esperarse como prueba en posibles acciones legales.

La información obtenida de la evaluación de los incidentes de seguridad de los sistemas orientados a Internet debería utilizarse para identificar incidentes recurrentes o relacionados, con el fin de planificar y aplicar cambios para reducir la probabilidad o el impacto de futuros incidentes similares. Herramientas

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

como los IPS y los SGSI pueden reconfigurarse basándose en la evaluación de los incidentes de seguridad y pueden iniciarse las modificaciones de política pertinentes para prevenir futuros incidentes.

La GTC-ISO/IEC 27002 y la serie de normas ISO/IEC 27035 ofrecen orientación adicional sobre la gestión de incidentes.

9.2.6 Gestión de activos

Deberían identificarse los componentes de las TIC que contengan información y aplicaciones críticas. Tradicionalmente, se ha esperado que las organizaciones sepan dónde se encuentran físicamente sus activos para protegerlos de una forma adecuada. Las organizaciones no solo deberían mantener un inventario actualizado de los activos de TIC bajo su control, sino que también deberían mantener un registro de activos de información sobre dónde se procesa, almacena y transfiere su información, tanto si se encuentra en su red interna como si utiliza soluciones de alojamiento basadas en la nube o en Internet. De esta manera, la organización puede gestionar los riesgos de su información dondequiera que resida y tomar decisiones basadas en el riesgo sobre si es apropiado que esa información se almacene fuera del entorno de control de la organización. Del mismo modo, en el caso de los componentes de red, se espera que las organizaciones sepan dónde se encuentran los activos sensibles con respecto a los puntos de entrada de posibles atacantes. Puede tratarse del acceso oficial a Internet, a través del cortafuegos, y de todas las demás conexiones con dispositivos, (por ejemplo, smartphones, dispositivos de IoT). También deberían identificar las rutas críticas utilizadas para tener acceso a activos TIC sensibles o para transportar información sensible dentro de la red de la organización. Estas rutas no deberían ser visibles, accesibles o supervisables por intrusos. Sin este conocimiento, no es posible una segregación adecuada de las redes. Este inventario debería adoptar la forma de una arquitectura (ubicación de las funcionalidades) e infraestructura de red que indique claramente, en ambas, los puntos de entrada/conexión con Internet (todas las redes interconectadas).

Se deberían identificar, documentar e implementar reglas para el uso aceptable y procedimientos para el manejo de activos, de otros activos asociados a Internet, y de instalaciones de procesamiento relacionadas. Las organizaciones deberían tener y utilizar un procedimiento para evaluar la criticidad de la información y de los activos TIC que la contienen y transfieren. Esto permitiría a la organización identificar claramente qué debería protegerse y a qué nivel en términos de políticas genéricas y seguridad de redes.

La GTC-ISO/IEC 27002 ofrece orientación adicional sobre la gestión de activos.

9.2.7 Gestión de proveedores

Deberían identificarse y aplicarse procesos y procedimientos para gestionar los riesgos de seguridad de Internet asociados al uso de proveedores. Todos los requisitos de seguridad de la información pertinentes deberían establecerse y acordarse con cada proveedor, en función del tipo de proveedor y de los riesgos asociados. La gestión de riesgos en relación con los proveedores de TIC y la información que almacenan, explotan o a la que pueden tener acceso, es clave para preparar contratos que garanticen el cumplimiento continuo de los objetivos de seguridad de la información de la organización.

Se deberían establecer y documentar acuerdos con los proveedores relacionados con Internet (como los PSI y los proveedores de servicios en la nube a través de Internet) para asegurar que existe un entendimiento claro entre la organización y los proveedores respecto a las obligaciones de ambas partes para cumplir los requisitos pertinentes de seguridad de la información. Las organizaciones

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

deberían tener asociaciones abiertas con los PSI, los proveedores de servicios de telecomunicaciones, los proveedores de servicios en la nube y los socios para informar/avisar de las detecciones de amenazas entrantes. Se debería determinar y supervisar periódicamente la capacidad del proveedor de servicios de Internet para gestionar los servicios acordados de forma segura. Se espera que la organización y el proveedor de servicios lleguen a un acuerdo sobre el derecho de auditoría.

Para los servicios en la nube accesibles a través de Internet y suscritos por la organización, se espera que la organización revise y negocie los acuerdos de servicios en la nube con el o los proveedores de dichos servicios. La organización debería realizar la evaluación de riesgos pertinente para identificar los riesgos asociados con el uso de los servicios en la nube y gestionar los riesgos durante la vigencia del acuerdo. Se espera que el acuerdo de servicios en la nube aborde los requisitos de confidencialidad, integridad, disponibilidad y gestión de IIP de la organización. Para cualquier servicio en la nube en el que una organización no pueda negociar los términos del acuerdo, se espera que la organización entre al acuerdo con los ojos bien abiertos, que entienda los riesgos de utilizar el servicio y cómo gestionar estos riesgos durante la duración del acuerdo.

Las herramientas basadas en la nube, como las herramientas de reunión web, las herramientas de chat web y las herramientas de almacenamiento en la nube, suponen un riesgo para una organización si estas herramientas tienen fallas de seguridad inherentes que pueden ser explotadas por agentes malintencionados, por lo que es importante que la organización establezca controles de seguridad para el uso de estas herramientas basadas en la nube.

Para satisfacer los requisitos de seguridad de Internet identificados, se puede considerar la inclusión de los siguientes aspectos en los acuerdos:

a) Requisitos legales y reglamentarios, incluidos los requisitos de protección de la información por parte del PSI, como la protección frente a ataques DDoS y de otro tipo.

b) Obligación de cada parte contractual de aplicar un conjunto de controles acordado que incluya el control de acceso, el monitoreo de la red y del sistema, la elaboración de informes y la auditoría, así como las obligaciones del proveedor de cumplir los requisitos de seguridad de la organización.

c) Requisitos y procedimientos de gestión de incidentes (especialmente la notificación y la colaboración durante la reparación de incidentes).

d) Monitoreo, revisión y gestión de cambios de los servicios de los proveedores para asegurar que se cumplen los términos y condiciones de seguridad de la información de los acuerdos y que estos permiten el control de los niveles de desempeño del servicio, para verificar el cumplimiento de los acuerdos, controlar los cambios realizados por los proveedores y controlar los cambios en los servicios de los proveedores.

Las normas GTC-ISO/IEC 27002, ISO/IEC TR 23187 y GTC-ISO/IEC 27017, y la serie de normas ISO/IEC 27036, ofrecen orientaciones adicionales relacionadas con los proveedores.

9.2.8 Continuidad del negocio en Internet

Algunas actividades del negocio, como el comercio basado en Internet y otras actividades de comercio electrónico, dependen de la infraestructura de Internet dentro de la organización. Las interrupciones de los servicios de Internet pueden deberse a ataques DoS y DDoS por parte de agentes malintencionados, a un mal funcionamiento de los dispositivos perimetrales, o a cualquier interrupción por parte del PSI.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los ataques DoS y DDoS también pueden ser llevados a cabo por actores malintencionados en el extremo del PSI, los cuales pueden resultar en la interrupción completa de la red troncal de Internet. Las instalaciones de procesamiento de información deberían implementarse con la redundancia suficiente para cumplir los requisitos de disponibilidad.

Cualquier interrupción en la infraestructura de Internet constituye un riesgo de continuidad para la organización y debería ser abordado por la organización. Las organizaciones deberían planificar la adquisición de servicios de Internet de diferentes PSI para las medidas básicas de continuidad. Las organizaciones deberían desplegar medidas de seguridad para evitar interrupciones, como medidas anti-DDoS para la continuidad de los dispositivos de red. Las organizaciones también pueden exigir a los respectivos PSI que desplieguen medidas anti-DDoS dentro de la red del PSI. Independientemente del servicio de continuidad, las organizaciones deberían seguir tomando en consideración la seguridad de la información en cualquier solución, inclusive cuando estén en modo de continuidad de negocio.

Las GTC-ISO/IEC 27002, NTC-ISO 22301 y GTC-ISO/IEC 27031 ofrecen orientaciones adicionales relacionadas con la continuidad de las TIC.

9.2.9 Protección de la privacidad en Internet

La mayoría de los proveedores de servicios controlan o procesan IIP. Cuando esta información se utiliza para fines distintos de los intereses del titular de los datos, surgen problemas de privacidad. Un proveedor de servicios de alojamiento procesa IIP en su red y centro de datos como parte de sus servicios empresariales. Estos servicios, que incluyen sitios web y otras aplicaciones en línea, con frecuencia son reempaquetados y revendidos por los suscriptores del servicio de alojamiento a otros consumidores, como pequeñas empresas y usuarios finales, y son accesibles a través de Internet.

Si los suscriptores de alojamiento instalan un servidor inseguro o alojan contenidos maliciosos en sus sitios o aplicaciones, la seguridad de los consumidores, incluida la IIP almacenada por dichas aplicaciones en línea, se verá afectada negativamente. Por ello, es importante que los servicios, como mínimo, cumplan las normas de mejores prácticas, mediante el cumplimiento de los términos mínimos de los acuerdos que cubren los requisitos de privacidad de los usuarios. Además de las disposiciones sobre protección de datos y privacidad personal en el sitio o aplicación orientados a Internet, los proveedores de servicios deberían exigir que tales sitios o aplicaciones alojados en sus redes apliquen una serie de controles de seguridad de mejores prácticas a nivel de aplicación, antes de su puesta en marcha. Antes de suscribirse a un servicio en Internet, las organizaciones deberían realizar una evaluación del impacto sobre la privacidad (PIA, por su sigla en inglés) para identificar la información personal que se puede utilizar, recopilar, procesar, almacenar o transmitir, y los riesgos asociados para la privacidad, con el fin de determinar si son aceptables para la organización y gestionarlos en consecuencia. Esto no solo incluye la recopilación de datos de clientes para prestar un servicio, sino que también puede incluir la recopilación de metadatos como direcciones IP o datos de geolocalización de personas que navegan por sitios web. Las organizaciones deberían publicar un aviso de privacidad en su sitio web para informar claramente a todos sus usuarios de los requisitos para interactuar con los servicios en línea de la organización. El enmascaramiento de datos debería utilizarse de acuerdo con la política de la organización en materia de control de acceso y los requisitos empresariales, tomando en consideración los requisitos legales. Las medidas de DLP deberían aplicarse a los sistemas y redes que procesan, almacenan o transmiten información sensible. Existen funciones tecnológicas en algunos navegadores de Internet que permiten al usuario cambiar la configuración de privacidad.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las GTC-ISO/IEC 27002, NTC-ISO/IEC 27701, NTC-ISO/IEC 29100 y NTC-ISO/IEC 27018 ofrecen orientaciones adicionales relacionadas con la privacidad.

9.2.10 Gestión de la vulnerabilidad

Debería obtenerse, oportunamente, información sobre las vulnerabilidades de los sistemas de TIC utilizados. Se debería evaluar la exposición de la organización a dichas vulnerabilidades, y se deberían tomar las medidas adecuadas para abordar el riesgo asociado. Se deberían establecer, documentar, implementar, monitorear y revisar las configuraciones, incluidas las configuraciones de seguridad de *hardware*, *software*, servicios y redes.

Las organizaciones que suministran productos tecnológicos (cortafuegos, IDS, IPS, entre otros) y servicios (servicios de red, servicios VoIP, servicios de seguridad gestionada, entre otros) deberían implementar, de forma consistente y eficaz, medidas para identificar, tratar y revelar las vulnerabilidades de los productos y servicios que suministran. A partir de las vulnerabilidades reveladas por los proveedores de productos y servicios, se aplican medidas de protección adecuadas para enfrentar las vulnerabilidades.

Con la creciente proliferación de *malware* en Internet, una organización proveedora de servicios puede recibir informes relacionados con infecciones por *malware* y programas espías, y con otros problemas de seguridad. Esta información es importante y útil para que los proveedores pertinentes evalúen el riesgo de infección por *malware* y proporcionen actualizaciones de las herramientas necesarias para asegurar que cualquier nuevo *malware* o programa espía detectado pueda eliminarse o desactivarse eficazmente. En este sentido, una organización debería ponerse en contacto con los proveedores de seguridad y enviarles informes pertinentes y muestras de *malware* para su seguimiento, sobre todo si parece haber un repunte en la prevalencia. La mayoría de proveedores mantienen una lista de correo electrónico para recibir dichos informes o muestras para su análisis y seguimiento.

La instalación incontrolada de *software* en los dispositivos informáticos puede llevar a la introducción de vulnerabilidades. La organización debería definir y aplicar una política estricta sobre qué tipos de *software* pueden instalar los usuarios. Los parches de *software* deberían aplicarse cuando puedan ayudar a eliminar o reducir vulnerabilidades de seguridad.

El *software* suministrado por un proveedor que se utilice en sistemas de operación de negocio a través de Internet debería mantenerse a un nivel soportado por el proveedor. Con el tiempo, los proveedores de *software* dejan de dar soporte a versiones antiguas de *software*. La organización debería considerar los riesgos de depender de *software* no soportado, incluido el *software* de código abierto, cuando se utiliza en sistemas de operación de negocios. El *software* de código abierto utilizado en sistemas de operación de negocios debería mantenerse en la última versión adecuada del *software*.

Otras medidas para mitigar las vulnerabilidades son:

a) Cambiar las prácticas operacionales.

b) Reconfigurar los sistemas técnicos.

c) Evitar el riesgo mediante la gestión del acceso a Internet.

d) Formar al personal y a los usuarios.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) Aplicar medidas de defensa en profundidad, es decir, cuando falla un control, existe otro método independiente para seguir defendiéndose.

f) Pruebas de seguridad del sistema, un SDLC seguro, y pruebas de parches y actualizaciones antes de su aplicación.

Las normas GTC-ISO/IEC 27002, ISO/IEC 30111 e ISO/IEC 29147 ofrecen orientaciones adicionales relacionadas con la gestión de vulnerabilidades.

9.2.11 Gestión de la red

Reducir la exposición de los activos conectados a Internet reduce los riesgos relacionados con el acceso no autorizado, la manipulación indebida o los daños. Se deberían establecer controles para asegurar la seguridad de la información conectada a Internet y la protección de los servicios conectados, frente a accesos no autorizados. Se deberían establecer controles para salvaguardar la confidencialidad e integridad de los datos que pasan por Internet y para proteger los sistemas y aplicaciones conectados. Los sistemas que pueden conectarse a Internet deberían estar restringidos y, cuando se permitan, deberían autenticarse. El registro y el monitoreo de los dispositivos y sistemas de red asociados a la infraestructura de Internet de la organización deberían aplicarse para registrar y detectar acciones que puedan afectar a la seguridad de Internet o que sean pertinentes para la misma. La organización debería considerar gestionar la seguridad de los sistemas conectados a Internet mediante la segregación de estos de otras redes organizativas, como redes privadas y DMZ. El perímetro de esta red segregada debería estar bien definido y debería controlarse mediante un puerto de enlace (por ejemplo, cortafuegos, enrutador de filtrado).

Para la implementación de la seguridad de redes se debería tener en cuenta lo siguiente:

- Asegúrese de que existe una interfaz monitoreada y confiable entre la red de la organización e Internet, que también garantice el control de acceso de todas las entidades, y no solo de las personas autorizadas. La información y las aplicaciones también deberían controlarse antes de conceder acceso tanto a la infraestructura interna como desde ella.

- Estructure la red interna para aislar los activos altamente críticos de los activos de uso general, con la creación de una especie de silos o *clusters* con un control de acceso adecuado. Asegurar subredes con enrutadores de filtrado y subredes incrustadas, para evitar tener un camino directo a los activos críticos.

- Monitoree y analice el tráfico interno para detectar y bloquear actividades ilícitas.

- Asegurar la preservación del acceso a y uso de Internet y sus servicios (incluida la comunicación con el personal que trabaja fuera de las instalaciones físicas).

- Asegurar que la red interna esté suficientemente segregada con protecciones de fronteras internas, para aislar los componentes críticos o cruciales de los puntos de entrada y de los canales de transferencia internos de fácil acceso.

Se deberían formular normas sobre el uso de Internet y los servicios a los que se accede a través de Internet, las cuales cubran, como mínimo, los siguientes aspectos:

a) Los servicios de red a través de Internet a los que el usuario puede acceder y los procedimientos de autorización para dichos servicios.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) Los controles y procedimientos tecnológicos y de gestión de la red para proteger el acceso a las conexiones a Internet y a los servicios de red a través de Internet.

c) Los medios utilizados para acceder a Internet y a los servicios a través de Internet (por ejemplo, HTTPS, VPN).

d) El monitoreo de los servicios a los que se accede a través de Internet (por ejemplo, monitoreo del ancho de banda, SIEM).

Un cortafuegos es un dispositivo crítico del perímetro de la red y las organizaciones deberían considerar tecnologías de cortafuegos que puedan enfrentar mejor a los ataques basados en Internet. El objetivo de este dispositivo es proporcionar protección frente a las amenazas procedentes de Internet e impedir la transferencia incontrolada de información privada al Internet. Las tecnologías de enrutador se pueden desplegar con funciones incorporadas o módulos adicionales para mejorar la seguridad de redes, y pueden enfrentar riesgos cibernéticos como los ataques DoS y DDoS.

Las tecnologías IDS e IPS basadas en red pueden desplegarse con inteligencia artificial y aprendizaje automático para enfrentar los ataques avanzados basados en Internet, incluidos los ataques con patrones de firma y comportamiento conocidos. Dependiendo de su configuración de su red, las organizaciones pueden considerar dispositivos de red que incluyan varios módulos de seguridad de red incorporados, como cortafuegos, IPS, DLP y protección contra ataques dirigidos a DNS.

La GTC-ISO/IEC 27002 y la serie de normas ISO/IEC 27033 ofrecen orientación adicional sobre la seguridad de redes.

9.2.12 Protección contra *malware*

El *software* anti*malware* escanea datos y programas para identificar patrones sospechosos asociados a *malware*. Para permitir la detección de nuevos códigos maliciosos, es muy importante asegurar que el *software* de análisis se mantiene siempre actualizado, de ser posible, mediante actualizaciones diarias.

Dado el potencial de que nuevos *malware* ataquen vulnerabilidades de día cero, existe *software* que puede identificar variantes conocidas. Esto comprende tecnología que puede identificar patrones de ataque potenciales. Aunque no es infalible, este *software* proporciona un mayor nivel de protección que si no se utiliza. Varios sistemas operativos populares tienen algunas funciones integradas para proteger contra el *malware* común, pero aun así deberían complementarse con tecnología anti*malware* en entornos de mayor riesgo.

La implementación de anti*malware* debería ampliarse a la protección del tráfico y el intercambio no deseados en Internet (en ambas direcciones), ya que los usuarios suelen recibir y enviar *malware* sin saberlo. Se deberían implementar medidas de prevención, detección, corrección y recuperación para proteger contra *malware*, combinadas con una adecuada concienciación de los usuarios.

La organización debería tomar en consideración las siguientes orientaciones:

a) El uso de *software* anti*malware* en los puertos de enlace a Internet, para escanear todo el tráfico hacia y desde Internet, incluyendo todos los protocolos de red autorizados para su uso.

b) El uso de *software* anti*malware* en todos los sistemas cliente, especialmente en los utilizados para el acceso a Internet por parte de los empleados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) El escaneo de archivos, correos electrónicos, archivos adjuntos de mensajería instantánea, páginas web y enlaces externos, en busca de virus, *ransomware*, troyanos y otras formas de *malware*.

d) El bloqueo de ventanas emergentes sospechosas, anuncios en la web, sitios web conocidos por ser maliciosos o sospechosos de serlo, y el uso de listas de bloqueo para servicios no autorizados, por ejemplo, canales de chat o servicios de correo web.

e) La concienciación de los usuarios de que existen mayores riesgos asociados al *malware* cuando se trata con terceros a través de enlaces externos.

f) La verificación de que se reciba información precisa relativa al *malware*, procedente de fuentes calificadas y acreditadas (por ejemplo, sitios de Internet fiables o proveedores de *software* anti*malware*).

g) La implementación del registro y monitoreo de todos los servicios que permitan la posibilidad de transferir datos hacia Internet.

h) La restricción del uso de servicios no autorizados que permitan la transferencia de grandes cantidades de datos.

i) La implementación de filtros para protocolos no autorizados, por ejemplo, protocolos de red *peer-to-peer*.

j) La aplicación de parches contra las vulnerabilidades conocidas del sistema en plazos basados en la criticidad de la vulnerabilidad, enfocada en todos los sistemas que reciben tráfico de Internet.

k) La configuración de los sistemas y aplicaciones a los que se accede a través de Internet, para desactivar funciones que no sean necesarias (por ejemplo, las macros).

l) La preparación de planes adecuados para recuperarse de los ataques con *malware*, que incluyen todas las copias de seguridad de datos y programas informáticos necesarias (tanto en línea como fuera de línea) y las disposiciones para recuperación.

La GTC-ISO/IEC 27002 ofrece orientaciones adicionales sobre la protección contra *malware*.

9.2.13 Gestión del cambio

Se deberían establecer políticas y procesos de gestión de cambios, para asegurar que a las organizaciones les resulte más fácil implementar cambios en la infraestructura de TI y gestionar cambios en los sistemas y aplicaciones de TI, con el fin de evitar interrupciones no programadas y la corrupción o pérdida de datos. Las organizaciones deberían incluir los cambios relacionados con la seguridad de los sistemas alojados en Internet en su proceso de gestión de cambios. Estos procesos ayudan a la organización a solicitar, priorizar, autorizar, aprobar, programar y aplicar cualquier cambio. Las políticas de gestión de cambios comprenden también declaraciones sobre responsabilidades y deberes de los gestores de sistemas, importación de *software* y archivos, control de acceso, entre otros. Todos los cambios (modificaciones, movimientos, supresiones o adiciones) de los componentes o la estructura de la red deberían gestionarse para mantener actualizados la arquitectura y los planos de la infraestructura.

La GTC-ISO/IEC 27002 ofrece orientaciones adicionales sobre la gestión de cambios.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

9.2.14 Identificación de la legislación aplicable y de los requisitos de conformidad

Internet se utiliza cada vez más como plataforma para implementar numerosos servicios de transacciones en línea. Puede haber leyes y reglamentos de seguridad de datos, ciberseguridad y privacidad sobre la protección de la confidencialidad, integridad y disponibilidad de los detalles de las transacciones.

Las transacciones bancarias, los canales de pago, las transacciones basadas en aplicaciones móviles y otras actividades de comercio electrónico suelen estar reguladas debido a la implicación del dinero en forma digital. Se deberían identificar, documentar y mantener actualizados todos los requisitos legales, estatutarios, reglamentarios y contractuales pertinentes en materia de seguridad de la información y ciberseguridad, así como el enfoque de la organización para cumplir estos requisitos.

Se espera que los registros mantenidos en sistemas en línea a los que se accede a través de Internet estén protegidos frente a pérdidas, destrucción, falsificación, acceso no autorizado y divulgación no autorizada, de acuerdo con los requisitos legales, estatutarios, reglamentarios, contractuales y empresariales. Los registros pueden ser necesarios como prueba de que una organización opera dentro de las normas legales o reglamentarias, para asegurar la defensa contra posibles acciones civiles o penales, o para confirmar el estado financiero de una organización a las partes interesadas.

La GTC-ISO/IEC 27002 ofrece orientación adicional sobre legislación y requisitos de conformidad.

9.2.15 Utilización de la criptografía

La criptografía es una de las formas de asegurar la protección de la información transmitida y evitar el análisis del tráfico. Una red privada virtual (VPN) es una solución sencilla. La criptografía tiene algunas limitaciones asociadas a la gestión de las claves de cifrado y descifrado y a la gestión de los dispositivos criptográficos, que deberían considerarse confidenciales y críticas.

La criptografía debería utilizarse para proteger la confidencialidad, autenticidad y/o integridad de la información transmitida por Internet. La implementación de VPN y HTTPS (protocolo seguro de transferencia de hipertexto) utiliza criptografía para conexiones seguras. Los algoritmos criptográficos, la longitud de las claves y las prácticas de uso deberían seleccionarse de acuerdo con las mejores prácticas. Una gestión de claves adecuada requiere procesos seguros para generar, almacenar, archivar, recuperar, distribuir, retirar y destruir claves criptográficas.

Todas las claves criptograficas deberían estar protegidas contra modificaciones y pérdidas. Además, las claves secretas y privadas necesitan protección contra el uso no autorizado, así como contra su divulgación. El equipo utilizado para generar, almacenar y archivar claves debería protegerse físicamente cuando sea pertinente. Al utilizar la criptografía, se debería tomar en consideración que se pueden aplicar diferentes normativas y restricciones nacionales al uso de técnicas de criptografía y a las cuestiones de flujo transfronterizo de información cifrada.

La GTC-ISO/IEC 27002 ofrece orientaciones adicionales sobre el uso de criptografía.

9.2.16 Seguridad de las aplicaciones para Internet

Pueden adoptarse nuevas tecnologías para los sistemas que forman parte de la infraestructura de Internet. La nueva tecnología debería ser analizada para detectar riesgos de seguridad, y el diseño debería ser revisado frente a patrones de ataque conocidos. La seguridad debería integrarse durante

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

el diseño del sistema. Los sistemas también deberían revisarse periódicamente, para asegurar que se mantienen actualizados en términos de lucha contra cualquier nueva amenaza potencial y para que sigan siendo aplicables a los avances en las tecnologías y soluciones que se aplican.

Las organizaciones deberían adoptar principios de ingeniería segura, incluida la aplicación de un ciclo de vida de desarrollo seguro, para identificar y mitigar los riesgos en los productos y soluciones que se están desarrollando. Esto debería considerar la modelización de amenazas, las técnicas de autenticación de usuarios, los componentes de la cadena de suministro, el control de sesiones seguras y la validación de datos, el saneamiento y una revisión del diseño orientada a la seguridad para ayudar a identificar las vulnerabilidades de seguridad en los sistemas orientados a Internet. El código de las aplicaciones orientadas a Internet se diseña mejor, desde el punto de vista de la seguridad, partiendo de la base de que siempre está sujeto a ataques, ya sea por error o por eventos malintencionados.

Las organizaciones deberían establecer reglas para el uso seguro y apropiado de los recursos a través de Internet, incluida cualquier restricción sobre sitios web y aplicaciones basadas en web indeseables o inapropiadas, y deberían informar a su personal consecuentemente. Esto disuade al personal de intentar acceder a dichos sitios. Las normas deberían mantenerse actualizadas. Estos sitios web pueden contener información ilegal, virus y material de *phishing*. Una técnica para restringir los sitios web indeseables o inapropiados consiste en bloquear la dirección IP o el dominio del sitio web en cuestión. Algunos navegadores y tecnologías anti*malware* pueden hacerlo automáticamente o pueden configurarse para ello.

Para diseñar y desarrollar aplicaciones, deberían seguirse normas de codificación seguras. Si el propietario de la aplicación puede acceder a los scripts mediante un acceso remoto directo al servidor, en principio también puede hacerlo un atacante. Los servidores web deberían configurarse para evitar la navegación por directorios en estos casos. Las orientaciones de la OWASP [23, 24] pueden ser una referencia útil para el diseño y las pruebas de aplicaciones seguras.

Las organizaciones deberían documentar el comportamiento del código y hacer una evaluación sobre si el comportamiento puede caer en áreas potenciales que puedan considerarse como programas espía o *software* engañoso. En este último caso, las organizaciones deberían contratar a un asesor debidamente calificado para que evalúe si el código entra dentro de los criterios objetivos de los proveedores de programas antiespía que se adhieran a las mejores prácticas. Esto puede asegurar que las herramientas de *software* proporcionadas por las organizaciones a los usuarios finales no se etiqueten como programas espía por los proveedores de programas antiespía. Muchos proveedores de programas antiespía publican los criterios bajo los que califican el *software*.

Las organizaciones deberían implementar la firma digital del código de sus binarios, para que los proveedores de anti*malware* y programas antiespía puedan determinar fácilmente el propietario de un archivo. El *software* producido sistemáticamente por ISV que utilizan las mejores prácticas, incluida la firma digital del código, puede clasificarse como probablemente seguro. Si una organización descubre técnicas de *software* útiles que pueden ayudar a reducir el problema de los programas espía o *malware*, la organización debería considerar asociarse y trabajar con el proveedor para que estén ampliamente disponibles.

Para las aplicaciones en las que las transacciones se procesan a través de Internet, se debería tomar en consideración lo siguiente:

- Requisitos sobre el nivel de protección necesario para mantener la confidencialidad e integridad de los detalles de las transacciones.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

- Transmitir los datos de las transacciones a través de Internet con los controles de seguridad adecuados (por ejemplo, vía de transmisión cifrada, certificación digital).

- Almacenar los datos de las transacciones fuera de cualquier entorno de acceso público y asegurando que el medio de almacenamiento no sea directamente accesible desde Internet.

- Requisitos de resiliencia frente a ataques, que pueden incluir requisitos para proteger los servidores de aplicaciones implicados o para la disponibilidad de las interconexiones de red necesarias para prestar el servicio.

- Cuando exista la necesidad de un alto grado de confianza en la seguridad de los productos de *software*, los productos deberían validarse de forma independiente bajo el esquema de criterios comunes, como se describe en la serie de normas ISO/IEC 15408.

Las pruebas de seguridad deberían ser parte integral de las pruebas de sistemas o componentes antes de su exposición al Internet. La organización puede utilizar herramientas automatizadas, como herramientas de análisis de código y escáneres de vulnerabilidades, y debería verificar la corrección de los defectos relacionados con la seguridad antes de poner los sistemas en funcionamiento en Internet.

Las pruebas de seguridad deberían incluir pruebas de:

a) Funciones de seguridad, por ejemplo, autenticación de usuarios, restricción de acceso, uso seguro de API y uso de criptografía.

b) Configuraciones seguras, incluidas las de los sistemas operativos, cortafuegos y otros componentes de seguridad.

La serie de normas ISO/IEC 15408 ofrece orientación sobre el aseguramiento de las aplicaciones. La GTC-ISO/IEC 27002 y la serie de normas ISO/IEC 27034 ofrecen orientaciones relacionadas con la seguridad de las aplicaciones.

9.2.17 Gestión de dispositivos de punto final

Se debería proteger la información almacenada en, procesada por o accesible a través de dispositivos de punto final (dispositivos de IoT, dispositivos USB, BYOD, entre otros). Se debería controlar de forma adecuada el transporte y el uso de dispositivos de punto final en zonas seguras. Se debería desarrollar e implementar una estrategia de seguridad para la gestión de dispositivos de punto final. Esta estrategia debería incluir la gestión de cortafuegos de dispositivos, herramientas de filtrado específicas para el correo electrónico, seguridad y filtrado de Internet, herramientas de gestión y seguridad de dispositivos móviles, cifrado y herramientas de detección de intrusiones.

La seguridad de los puntos finales se ha vuelto aún más importante, ya que éstos se están moviendo fuera del perímetro de la organización y los usuarios pueden utilizar Internet para acceder a la nube y a los recursos dentro de la red de la organización. Al comprometimiento del punto final debería responderse con una acción inmediata para bloquear al atacante y limitar daños mayores. Las organizaciones deberían desplegar capacidades técnicas en los puntos finales para detectar cualquier tráfico malicioso de fuentes desconocidas y actores maliciosos y responder. Estas tecnologías también se conocen como tecnologías de detección y respuesta de punto final (EDR). Las organizaciones deberían disponer de un mecanismo que garantice que todas las políticas de seguridad de la organización aplicables a los sistemas y dispositivos de los usuarios finales estén activadas en todo

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

momento. Estas tecnologías deberían asegurarse de que el usuario final no pueda desactivar o eludir las funciones de seguridad instaladas en su punto final.

La pérdida o comprometimiento del punto final puede suponer un riesgo importante para los datos que residen en el punto final, lo que incluye los dispositivos móviles. Las organizaciones deberían implementar técnicas para asegurar que pueden rastrear estos dispositivos y, en caso de pérdida o comprometimiento del dispositivo, deberían ser capaces de borrar remotamente el contenido de los dispositivos, incluso antes de que los datos sean robados por los actores malintencionados.

La GTC-ISO/IEC 27002 ofrece orientaciones adicionales sobre la gestión de dispositivos de punto final.

9.2.18 Monitoreo

Se deberían producir, proteger, conservar y analizar registros de las actividades, excepciones, fallas y otros eventos pertinentes. Los registros se deberían proteger y guardar en un lugar seguro para realizar el análisis y auditoría de registros. Algunas normativas exigen almacenar los registros durante un periodo de tiempo determinado. Las redes, sistemas y aplicaciones orientados a Internet deberían monitorearse para detectar comportamientos anómalos, y deberían tomarse medidas adecuadas para evaluar posibles incidentes de seguridad de la información.

La GTC-ISO/IEC 27002 ofrece orientación adicional sobre el monitoreo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ANEXO A
(Informativo)

REFERENCIAS CRUZADAS ENTRE ESTE DOCUMENTO Y LA GTC-ISO/IEC 27002

La Tabla A.1 muestra la correspondencia entre los controles para la seguridad en Internet citados en el numeral 9.2 de este documento y los controles contenidos en la GTC-ISO/IEC 27002. Cada columna contiene el número y título del subnumeral correspondiente.

Tabla A.1 - Correspondencia entre controles para la seguridad en Internet

NTC-ISO/IEC 27032		GTC-ISO/IEC 27002:2022	
9.2.2	Políticas de seguridad en Internet	5.1 5.4	Políticas de seguridad de la información Responsabilidades de la dirección
9.2.3	Control de acceso	5.15 5.16 5.17 8.2 8.18	Control de acceso Gestión de identidades Derechos de acceso Derechos de acceso privilegiado Uso de programas de utilidad con privilegios
9.2.4	Educación, concienciación y formación	6.3	Concienciación, educación y formación en materia de seguridad de la información
9.2.5	Gestión de incidentes de seguridad	5.7 5.24 5.25 5.26 5.27 5.28 6.8	Inteligencia sobre amenazas Planificación y preparación de la gestión de incidentes de seguridad de la información Evaluación y decisión sobre incidentes de seguridad de la información Respuesta a incidentes de seguridad de la información Aprender de los incidentes de seguridad de la información Recopilación de evidencias Informes de eventos de seguridad de la información
9.2.6	Gestión de activos	5.9 5.10 5.11 5.12	Inventario de la información y de otros activos asociados Uso aceptable de la información y de otros activos asociados Devolución de activos Clasificación de la información
9.2.7	Gestión de proveedores	5.19 5.20 5.21 5.22 5.23	Seguridad de la información en las relaciones con los proveedores Abordaje de la seguridad de la información en los acuerdos con los proveedores Gestión de la seguridad de la información en la cadena de suministro de TIC Monitoreo, revisión y gestión de cambios de los servicios de proveedores Seguridad de la información para el uso de servicios en la nube
9.2.8	Continuidad del negocio en Internet	5.29 5.30 8.13	Seguridad de la información durante una interrupción Disponibilidad de las TIC para la continuidad del negocio Copia de seguridad de la información

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

NTC-ISO/IEC 27032	GTC-ISO/IEC 27002:2022
	8.14 Redundancia de las instalaciones de procesamiento de la información
9.2.9 Protección de la privacidad en Internet	5.34 Privacidad y protección de IIP 8.11 Enmascaramiento de datos
9.2.10 Gestión de la vulnerabilidad	8.8 Gestión de las vulnerabilidades técnicas 8.9 Gestión de la configuración 8.19 Instalación de *software* en sistemas de operación de negocio
9.2.11 Gestión de la red	8.16 Actividades de monitoreo 8.20 Seguridad de las redes 8.21 Seguridad de los servicios de red 8.22 Segregación de redes
9.2.12 Protección contra *malware*	8.7 Protección contra *malware*
9.2.13 Gestión del cambio	8.32 Gestión del cambio
9.2.14 Identificación de la legislación aplicable y de los requisitos de conformidad	5.28 Recogida de pruebas 5.31 Requisitos legales, reglamentarios y contractuales 5.33 Protección de documentos
9.2.15 Utilización de criptografía	8.24 Utilización de criptografía
9.2.16 Seguridad de las aplicaciones para Internet	8.23 Filtrado web 8.24 Utilización de criptografía 8.25 Ciclo de vida del desarrollo seguro 8.26 Requisitos de seguridad de las aplicaciones 8.27 Arquitectura de sistemas seguros y principios de ingeniería 8.28 Codificación segura 8.29 Pruebas de seguridad en el desarrollo y la aceptación
9.2.17 Gestión de dispositivos de punto final	8.1 Dispositivos de punto final de usuario 8.9 Gestión de la configuración
9.2.18 Monitoreo	8.15 Registro de datos 8.16 Actividades de monitoreo

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

BIBLIOGRAFÍA

[1] ISO 9000:2015, *Quality management systems — Fundamentals and vocabulary*

[2] ISO/IEC 15408 (todas las partes)

[3] ISO 19101-1:2014, *Geographic information — Reference model — Part 1: Fundamentals*

[4] ISO 22301:2019, *Security and resilience — Business continuity management systems — Requirements*

[5] ISO/IEC/TR 23187:2020, *Information technology — Cloud computing — Interacting with cloud service partners (CSNs)*

[6] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*

[7] ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection —* Information security controls

[8] ISO/IEC 27005:2022, *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*

[9] ISO/IEC 27017:2015, *Information technology — Security techniques — Code of practice for information security controls based on* ISO/IEC 27002 *for cloud services*

[10] ISO/IEC 27018:2019, *Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors*

[11] ISO/IEC 27031:2011, *Information technology — Security techniques — Guidelines for information and communication technology readiness for business continuity*

[12] ISO/IEC 27033 (todas las partes), *Information technology — Security techniques — Network security*

[13] ISO/IEC 27034 (todas las partes), *Information technology — Application security*

[14] ISO/IEC 27035 (todas las partes), *Information technology — Security techniques — Information security incident management*

[15] ISO/IEC 27036 (todas las partes), *Information technology — Security techniques — Information security for supplier relationships*

[16] ISO/IEC/TS 27100*, Information technology — Cybersecurity — Overview and concepts*

[17] ISO/IEC 27701:2019*, Security techniques — Extension to ISO/IEC 27001 and ISO/IEC 27002 for privacy information management — Requirements and guidelines*

[18] ISO/IEC 29100:2011, *Information technology — Security techniques — Privacy framework*

[19] ISO/IEC 29146:2016, *Information technology — Security techniques — A framework for access management*

[20] ISO/IEC 29147:2018, *Information technology — Security techniques — Vulnerability disclosure*

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

[21] ISO/IEC 30111:2019, *Information technology — Security techniques — Vulnerability handling processes*

[22] ISO 31000:2018, *Risk management — Guidelines*

[23] OPEN WEB APPLICATION SECURITY PROJECT (OWASP), OWASP Web Security Testing Guide, [online] [viewed 2020-12-03]. Available at https://owasp.org/www-project-web-security-testing-guide/

[24] OPEN *WEB APPLICATION SECURITY PROJECT* (OWASP), OWASP Top 10, [online] [viewed 2022- 10-29]. Available at https://owasp.org/Top10/

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

DOCUMENTO DE REFERENCIA

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Cybersecurity. Guidelines for Internet security.* Ginebra, 2023, 28 p. (ISO/IEC 27032:2023)

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La normalización fomenta la productividad, competitividad y crecimiento sostenible. Tu participación en el proceso de normalización nos permite aportar a la construcción de un mejor país. **Accede a toda la información en los siguientes portales:**

icontec

e-conecta icontec

econecta.icontec.org/

La normalización a un clic. Participa en el proceso de Normalización de manera más activa a través de nuestra plataforma e-conecta.

e-collection icontec

ecollection.icontec.org/

Información que evoluciona, conocimiento que avanza. Conoce nuestro servicio de suscripción al catálogo de normas nacionales e internacionales que tenemos para ti. Más información cdi@icontec.org

Tienda Virtual

www.tienda.icontec.org

Conoce nuestra sala de consulta virtual y las normas técnicas, publicaciones y cursos de tu interés, por medio de la tienda virtual.

CAMPUS DIGITAL

www.campus.icontecvirtual.edu.co

Conoce nuestra oferta académica y los recursos educativos gratuitos que ponemos a tu disposición para impulsar tu desarrollo.

Somos expertos en cada sector económico:



Tenemos una amplia presencia en Colombia y Latinoamérica

COLOMBIA

Apartadó
Armenia
Barranquilla
Barrancabermeja
Bogotá
Bucaramanga
Cali
Cartagena
Cúcuta
Manizales
Medellín
Montería
Ibagué
Neiva
Pereira
Pasto
Villavicencio

LATAM

Bolivia
Costa Rica
Chile
Ecuador
El Salvador
Guatemala
Honduras
México
México
Panamá
República Dominicana
Perú

Canales de atención al cliente:

Colombia: **#426**
Resto del país: **01 8000 94 9000**
cliente@icontec.org

Contamos con 60 años de trayectoria

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -
Impreso por: Consulta